

Common Ports — Study Guide

Every tool and technique you've studied so far — Nmap, NSE, Enum4linux, SMBMap, SNMP/LDAP/RPC — starts with the same question: *what's listening on which port?* This guide is the reference layer underneath all of it: knowing ports well enough that seeing `21/tcp open` in an Nmap scan immediately tells you what to try next, without needing to look anything up mid-engagement.

1. Why Memorizing Ports Actually Matters

Port numbers aren't random — they're a lookup table your brain should have instant access to during an engagement. When you see a port open in a scan, it should immediately trigger: *what protocol, what tool, what known weaknesses, what's my next command.* This is exactly the kind of fast pattern-recognition that separates "I ran Nmap" from "I know what to do with what Nmap found."

2. TCP vs UDP — Quick Refresher

- **TCP** — connection-oriented, reliable, used by most services you'll enumerate (web, SSH, SMB, RDP, databases)
- **UDP** — connectionless, faster but unreliable, used by DNS, SNMP, DHCP, NTP — often **under-scanned** by pentesters because UDP scanning is slow, which is exactly why it's worth doing anyway (SNMP findings from your last guide live here)

```
nmap -sS -p- target          # TCP - default SYN scan
nmap -sU --top-ports 20 target # UDP - much slower, scan
fewer ports
```

3. The Core Port Reference Table

File Transfer & Remote Access

Port	Protocol	Notes
21	FTP	Often allows anonymous login; plaintext creds — classic early win

Port	Protocol	Notes
22	SSH	Version banner reveals OS/distro hints; brute-force target
23	Telnet	Plaintext, no encryption — finding this open at all is a finding
69	TFTP (UDP)	No auth by design, often used on network devices/IoT for config files
989/990	FTPS	FTP over TLS/SSL
3389	RDP	Windows Remote Desktop — BlueKeep (CVE-2019-0708), credential brute-force target
5900	VNC	Often weak/no auth in misconfigured setups

Web

Port	Protocol	Notes
80	HTTP	Start here for dorking, directory brute-force, tech fingerprinting
443	HTTPS	Check cert (<code>ssl-cert</code> NSE script), SNI can reveal hostnames
8080	HTTP (alt)	Common for proxies, Tomcat, dev instances
8443	HTTPS (alt)	Common for admin panels, alt SSL services

Email

Port	Protocol	Notes
25	SMTP	Mail relay; check for open relay misconfig, user enum via VRFY
110	POP3	Mail retrieval, plaintext by default
143	IMAP	Mail retrieval, plaintext by default
465	SMTPS	SMTP over SSL
587	SMTP (submission)	Authenticated mail submission
993	IMAPS	IMAP over SSL
995	POP3S	POP3 over SSL

Directory Services / Windows-Centric

Port	Protocol	Notes
88	Kerberos	AD authentication — ASREPROast/Kerberoast target (ties to your LDAP guide)
135	MSRPC	Windows RPC endpoint mapper (your RPC guide)
139	NetBIOS Session	Legacy SMB transport
389	LDAP	Domain enumeration (your LDAP guide)
445	SMB	File sharing, RPC-over-SMB — Enum4linux/SMBMap territory
464	Kerberos (kpasswd)	Password change service
636	LDAPS	LDAP over SSL
3268	Global Catalog	AD forest-wide search (LDAP)
3269	Global Catalog SSL	
5985	WinRM (HTTP)	PowerShell remoting — lateral movement (your PowerShell guide)
5986	WinRM (HTTPS)	Encrypted WinRM

Databases

Port	Protocol	Notes
1433	MSSQL	Default creds/weak auth common; <code>xp_cmdshell</code> if you get in
1521	Oracle DB	TNS listener
3306	MySQL	Weak/default root creds a classic finding
5432	PostgreSQL	
6379	Redis	Frequently unauthenticated by default — direct RCE paths exist
9200	Elasticsearch	Frequently unauthenticated, massive data leak risk (your Shodan guide)
27017	MongoDB	Same story — unauthenticated instances are a recurring headline finding

Network Infrastructure

Port	Protocol	Notes
53	DNS (TCP/UDP)	Zone transfer checks (your DNS guide)
67/68	DHCP (UDP)	
123	NTP (UDP)	Can leak system uptime, sometimes used in DDoS amplification
161/162	SNMP (UDP)	Community string enum (your SNMP guide)
500	IPSec/IKE (UDP)	VPN negotiation
514	Syslog (UDP)	Log forwarding — worth knowing for SOC/blue-team context
1723	PPTP	Legacy VPN, known weak encryption

File Sharing / Misc

Port	Protocol	Notes
111	RPCbind/Portmapper	Linux/Unix RPC (your RPC guide — <code>rpcinfo</code>)
2049	NFS	Network File System — check exports with <code>showmount -e</code>
512/513/514	rlogin/rsh/rexec ("r-services")	Ancient, trust-based auth — rare but a huge finding if present

4. Ports Grouped by "What I Should Do Next" (The Genuinely Useful Way to Study This)

Rather than memorizing the table top-to-bottom, group ports by **your next action** — this is how experienced pentesters actually think during a scan:

"Try anonymous/default creds first"

```
21 (FTP anonymous)
23 (Telnet default creds)
161 (SNMP public/private)
1433/3306/5432 (default DB creds)
6379/9200/27017 (often no auth at all)
```

"Run the enumeration trio"

```
445 → Enum4linux, SMBMap  
389 → ldapsearch, ldapdomaindump  
135 → rpcclient
```

"Web recon starts here"

```
80/443/8080/8443 → gobuster, nikto, Google dorking, manual browsing
```

"This is a lateral movement / shell opportunity"

```
22 (SSH), 3389 (RDP), 5985/5986 (WinRM) → once you have valid creds
```

"This is worth a targeted CVE search"

```
445 (EternalBlue - MS17-010)  
3389 (BlueKeep - CVE-2019-0708)  
Any specific version banner from -sV → cross-reference NVD (exactly what your SmartScan project automates)
```

5. Practical Nmap Command Tied to This Table

```
# Full TCP sweep, no assumptions  
nmap -sV -sC -p- -T4 -oN full_scan.txt target  
  
# Fast check of just the highest-value ports from this guide  
nmap -sV -p21,22,23,25,80,443,445,3306,3389,5985,6379,9200,27017 target  
  
# Don't forget UDP - SNMP, DNS, NTP often get skipped  
nmap -sU --top-ports 20 target
```

6. Well-Known vs. Registered vs. Dynamic Port Ranges

Worth knowing the underlying structure, since it explains *why* ports are numbered the way they are:

Range	Category	Notes
0–1023	Well-known/system ports	Require root/admin to bind on Linux; standard services (21, 22, 80, 443, etc.)
1024–49151	Registered ports	Assigned to specific applications (3306 MySQL, 3389 RDP) but not OS-privileged
49152–65535	Dynamic/ephemeral ports	Used for temporary client-side connections, RPC dynamic port allocation

This is also why RPC (port 135) is often just an "endpoint mapper" — the actual service you're after gets assigned a random high port from the ephemeral range, which is why RPC enumeration tools query 135 first to *find out* which dynamic port to actually talk to.

7. Full Port Range Scanning — Why **p-** Matters

Scanning only the top 1000 ports (Nmap's default) misses services deliberately run on non-standard ports specifically to evade casual scanning — a surprisingly common practice for admin panels, backup services, or intentionally hidden management interfaces.

```
nmap -p- -T4 target
```

Always worth running a full-range scan at least once per engagement, even though it's slower — this is exactly the kind of thing that separates a thorough VAPT report from a superficial one.

8. Kill Chain / ATT&CK Mapping

Concept	Framework Mapping
Port scanning itself	T1046 (Network Service Discovery), T1595.001 (Active Scanning: Scanning IP Blocks)
Service-specific follow-up (e.g., SMB, RDP, DB)	Maps into the specific technique for that service (T1021.x for lateral movement protocols, T1110 for brute-forcing exposed auth)

Quick Reference Cheat Sheet

21	FTP	anonymous login check
22	SSH	version banner, brute-force target
23	Telnet	plaintext - finding it open is itself a finding
25	SMTP	open relay, VRFY user enum
53	DNS	zone transfer
80/443	HTTP/S	dorking, dir brute-force, nikto
88	Kerberos	ASREPROast/Kerberoast
135	MSRPC	rpcclient, endpoint mapper
139/445	SMB	Enum4linux, SMBMap
161	SNMP (UDP)	community string brute-force
389/636	LDAP/LDAPS	ldapsearch, domain dump
1433	MSSQL	default creds
1521	Oracle	
2049	NFS	showmount -e
3306	MySQL	default creds
3389	RDP	BlueKeep, brute-force
5432	PostgreSQL	
5900	VNC	weak/no auth
5985/5986	WinRM	lateral movement (creds needed)
6379	Redis	often unauthenticated
9200	Elasticsearch	often unauthenticated
27017	MongoDB	often unauthenticated